

硕士学位论文答辩 · 现场讲解稿

《基于自编码器的网络安全攻击基线方法与实现》· 对照 PPT 17 页逐页讲 · 手机读稿

SLIDE 1 · 封面

约 30 秒

开场自我介绍

各位老师好，我是黄沛竑，学号 M202340083，软件工程专业，数理学院，指导教师王卫苹教授。我今天答辩的题目是《基于自编码器的网络安全攻击基线方法与实现》。下面开始汇报。

操作 翻到第2页目录

SLIDE 2 · 目录

约 40 秒

五个部分的导览

我今天的汇报分五部分：第一部分讲研究背景，网络入侵检测目前面临的现实挑战；第二、三部分是论文的两项核心创新——创新一是多任务 Transformer 增强自编码器的基线生成方法，创新二是 k-Sigma 滑动窗口动态阈值判决方法；第四部分是系统实现与实验验证；第五部分总结与展望。

SLIDE 3 · 研究背景

约 1.5 分钟

现实挑战：三个问题

传统的签名检测没法识别未知攻击，深度学习方法又受限于分布漂移和类别不均衡，具体是三个问题：

第一，基线表示不足——签名匹配只能识别已知攻击，监督学习方法一旦碰到训练集分布之外的攻击，检测能力会骤降，零日攻击和变种攻击已经是常态了。

第二，阈值机制不完善——真实部署环境里，流量分布会随业务、时段、用户行为持续变化，离线训练好的固定阈值没法跟踪这种在线变化，误报率会随时间持续抬升。

第三，类别极度不均衡——CIC-IDS2018 里正常样本占绝大多数，SQL Injection 只有 9 条，Brute Force-XSS 只有 23 条，多数类主导训练，少数攻击类别很难学到。

操作 翻到第4页研究流程图

SLIDE 4-5 · 研究流程与论文架构

约 1 分钟

从问题到方法到系统的完整链路

这张图是整篇论文的路线图：从三个问题出发——P1基线表征不足、P2阈值机制不完善、P3类别不均衡；对应两项创新——创新一解决P1和P3，创新二解决P2；两项创新再集成为一个双子系统架构；最后在 CIC-IDS2018 数据集、9450条测试样本上，用6项核心指标做了完整的实验验证，包括整体性能对比、动态阈值验证、未知攻击检出、消融实验归因四个方面。

操作 翻到第6页，翻页时可以停顿一下让老师看架构图

SLIDE 6 · 两大核心环节

约 1.5 分钟

基线生成 → 基线偏离判决

论文围绕"基线生成"和"基线偏离判决"这两个相互衔接的环节展开。基线生成这一环节要回答三个问题：怎么建模流量特征间的全局依赖？怎么让基线同时具备生成式重构能力和判别式分类能力？怎么避免极端不均衡下多数类主导训练？这对应创新一——多任务 Transformer 增强自编码器。

基线偏离判决这一环节要回答另外三个问题：怎么让判决阈值随分布漂移自适应调整？怎么切断"漏报→漂移→更多漏报"这个正反馈？怎么保证流式场景下的实时响应？这对应创新二——k-Sigma 滑动窗口动态阈值。

操作 翻到第7页，进入创新一详细讲解

SLIDE 7 · 创新一的三个问题

约 1.5 分钟

表征、优化、训练三个环节的系统性局限

传统自编码器基线方法在三个环节上有系统性局限。**表征环节**：网络流量的攻击签名往往体现在多维特征的联合分布上，比如 DDoS 攻击体现为包速率、包长、流持续时间三者的联合异常，MLP 编码器只能逐层做局部变换，CNN 编码器假设局部空间相关性，都没法直接建模任意两维特征之间的全局依赖。

优化环节：只用重构损失训练，基线对未知攻击敏感但对已知类别缺乏判别力；只用分类损失训练，多分类信号会挤压重构通道，丧失对训练集外攻击的检测能力——这两个目标在潜在空间里存在固有张力，单任务方法兼顾不了。

训练环节：CIC-IDS2018 各类别样本数差异达 5 个数量级，重构损失被多数类主导，基线会退化成“正常流量重建器”；分类损失被多数攻击类主导，少数类的梯度被淹没。

操作 翻到第8页架构图

SLIDE 8 · ULTIMATEIDSNETWORK 架构

约 2 分钟

同时回应 P1、P2、P3 的架构设计

针对性地，我设计了这样一套架构：30 维流量特征输入，经过 4 个残差块把维度从 30 提升到 512；接着是核心部分——嵌入一个 3 层 8 头的 Transformer（前馈层维度 2048），对这 512 维特征做全局依赖建模，这是回应 P1 的关键设计；输出 512 维的潜在表示，也就是基线 z ；再经过 4 个残差块解码回 30 维，跟原始输入算重构损失。

在这个共享的 512 维潜在空间上，我并联了三个头：重构头输出 30 维重建、权重 1.0；多分类头做 15 类细粒度判别、权重 2.0；二分类头做攻击/正常判别、权重 1.5。总损失是三者加权求和。这个三任务联合优化框架是回应 P2 的设计——重构约束保持基线完整性，分类约束注入判别性。

$$L_{\text{total}} = 1.0 \cdot L_{\text{rec}} + 2.0 \cdot L_{\text{cls}} + 1.5 \cdot L_{\text{bin}}$$

P3 的不均衡问题，我从数据、特征、梯度三个层面协同处理：加权随机采样、Mixup 数据增强、Focal Loss，三层机制配合，不是单一手段。

操作 翻到第9页实验结果

SLIDE 9 · 创新一实验结果

约 1.5 分钟

整体性能与逐项验证

在 CIC-IDS2018 上，整体准确率 84.0%，加权平均 F1 达到 0.838，二分类 AUC 0.9395，AP 0.9415。这几个数字背后，我想强调三点观察：

第一，主要洪水类攻击 F1 都在 0.94 以上，验证了 Transformer 全局依赖确实能捕获多维联合签名；**第二**，AUC 0.9395、AP 0.9415，验证了共享编码器加三任务头带来的判别性；**第三**，只有9条样本的 SQL Injection，F1 也能到 0.615，这验证了数据-特征-梯度三层协同处理不平衡问题的价值——不是完美，但在极端小样本下依然学到了东西。

[操作](#) 翻到第10页，进入创新二

SLIDE 10 · 创新二的三个问题

约 1.5 分钟

传统阈值方法的三条失效路径

P4，分布漂移失效：离线训练的阈值是对历史正常分布的常量估计，部署环境里流量分布会持续漂移，原阈值越来越不匹配，误报率随时间持续抬升。

P5，漂移正反馈崩溃：如果漏报的攻击样本被错误纳入统计估计，会同时抬高均值和放大方差，导致阈值整体上漂；阈值上漂后，后续攻击更容易低于阈值，造成更多漏报，形成“漏报→漂移→更多漏报”的正反馈循环。EWMA、SmartSifter 这些经典方法都没有在机制层面解决这个问题。

P6，工程实时性约束：大规模流量场景要求微秒级决策延迟，传统全量重算均值方差是 $O(W)$ 时间复杂度，窗口大小1000时单次开销太大；而且直接用方差公式做大数据相减，长时间运行会有精度损失，数值会崩坏。

[操作](#) 翻到第11页算法核心

SLIDE 11 · 创新二算法核心

约 2 分钟

三个机制构件 + 一项关键创新

四个部件，逐一对应前面三个问题：**滑动窗口** ($W=1000$)，循环队列实时收录正常样本得分，回应P6；**Welford增量算法**， $O(1)$ 时间维护均值方差，避免大数相减的精度损失，也是回应P6；**k-Sigma阈值** ($\theta=\mu+1.5\sigma$)，每次统计量更新后即时刷新，让判决边界跟着基线分布同步调整，回应P4。

最关键的是第四个——**攻击样本隔离机制**，这是本章的核心创新点：被判定为异常的样本不入队、不参与统计量更新，从机制层面切断了漂移正反馈链，这是跟传统 EWMA 的根本区别，回应P5。

理论上我也给了保证：大数定律证明平稳条件下均值方差估计以概率1收敛于真实参数；中心极限定理证明估计误差以 $1/\sqrt{W}$ 速率衰减， $W=1000$ 对应的理论标准误差约 3.2%；鲁棒性上，10%攻击样本注入扰动下，完整机制F1只降2.4个百分点，没有隔离机制的版本降11.3个百分点——差距很明显。这套理论保证是独立于上游检测器形式的，意味着创新二可以作为通用判决组件，嵌入任何能输出异常得分的检测系统，不只是本文这一个模型。

[操作](#) 翻到第12页实验对比

SLIDE 12 · 创新二实验结果

约 1 分钟

三种阈值策略对比

跟固定阈值比，误报率相对下降30%，从12.4%降到8.7%，回应的是P4分布漂移问题；召回率比99%分位阈值提升9.5个百分点，从0.781到0.876，说明动态调整确实优于静态分位阈值；长期运行波动率32.5%，在10个时间窗口内保持稳定，回应的是P6工程实时性约束——不只是准确，还要跑得稳。

[操作](#) 翻到第13页实验设置

SLIDE 13 · 实验设置

约 1.5 分钟

数据、指标、训练配置

数据来自加拿大网络安全研究所的 CIC-IDS2018，原始规模约1600万条流量记录，我做了样本精简——大类各抽5000条、小类全保留，精简到94497条；特征筛选上，方差为零的剔除、皮尔逊相关系数大于0.95的剔除，最后保留30维。15类（含BENIGN和14类攻击），训练:验证:测试按8:1:1分层抽样，种子42，测试集9450条样本，用训练集拟合的StandardScaler做标准化。

评价指标包括准确率、加权F1、宏F1（对少数类敏感）、召回率、误报率FPR、二分类AUC。训练超参：800轮、批大小256、AdamW优化器、学习率3e-4，硬件用的NVIDIA RTX 4090。实验目标有三个：验证整体性能和创新点有效性、通过消融实验定量分析各模块贡献、通过未见攻击实验考察对训练分布外样本的响应能力。

[操作](#) 翻到第14页系统集成

SLIDE 14 · 双子系统集成

约 1.5 分钟

两大创新的系统级集成

训练子系统承载创新一：数据预处理、模型构建（UltimateIDSNetwork约1950万参数）、联合训练、AdamW加Warm-up加余弦退火的优化策略、最后持久化成best_model.pth。检测子系统承载创新二：加载模型、对到达样本计算30维统计量、复合评分、k-Sigma在线动态阈值、最终判决正常/已知/疑似未知。

两大创新之间的接口，是这个复合异常得分公式：

$$s = 0.7 \times \text{重构误差} + 0.3 \times \text{二分类概率}$$

重构通道保留对未知攻击的敏感性，分类通道引入对已知攻击的判别力，两条通道的信息在这一个标量分数里融合，再交给创新二的动态阈值去做判决。这是训练子系统和检测子系统解耦、又能协同工作的关键设计。

[操作](#) 翻到第15页未知攻击检测

SLIDE 15 · 未知攻击检测

约 2 分钟

两大创新的协同效应

为什么两大创新协同才能做未知攻击检测？创新一的重构通道对未知攻击会产生显著重构误差，这是"生成式信号"；创新一的分类通道，对未知攻击的最大分类概率会显著低于阈值 $\tau=0.7$ ，这是"不确定性信号"；创新二的动态阈值把这些偏离信号映射成可靠的判决，还能适应分布漂移。

判决流程分三步：算复合异常得分；跟动态阈值比较，小于等于阈值判正常，大于阈值进入下一步；再看最大分类概率是否 ≥ 0.7 ，是则输出已知攻击类别，否则标记疑似未知。

在留出的4类未知攻击上做协同增益验证：只用创新一提升8.5个百分点，只用创新二提升16.3个百分点，两者协同总提升24.8个百分点——**远大于两者单独提升之和**，这就是协同增益的证据，不是简单的1+1。

[操作](#) 翻到第16页消融实验

SLIDE 16 · 消融实验

约 1.5 分钟

各组件的贡献归因

创新一内部：多任务学习是核心，去掉之后F1下降5.4个百分点，是最大降幅；Transformer对未知攻击检测尤其关键，去掉之后未知攻击检出率下降8.6个百分点；数据-特征-梯度三层协同处理不均衡的方式不可替代，去掉之后F1下降4.5个百分点。

创新二内部：攻击样本隔离机制是关键组件，去掉之后误报率上升3.1个百分点。综合来看：**创新一负责"质"**——基线表征的判别性；**创新二负责"稳"**——长期运行的鲁棒性。两者分工明确，各自不可替代。

[操作](#) 翻到第17页总结展望

收尾

后续工作我想往两个方向深化：一是跨环境迁移能力，引入领域自适应、对抗训练或元学习，让基线生成器能快速适应新网络环境的流量特征，降低跨网络部署下的基线退化风险；二是层次化精细基线，针对业务结构复杂的真实网络，按业务、时段、用户角色分别构建子基线，通过分层判决提升细粒度异常识别能力。

最后，感谢导师王卫苹教授在课题选择、方法设计、论文撰写全过程的悉心指导，感谢数理学院软件工程专业提供的学习环境和实验条件，也要特别说明，本论文的工作与2024年CCF-绿盟科技"鲲鹏"科研基金项目紧密相关，感谢项目方提供的实践平台，让我能在真实的工业级网络安全场景中验证方法的可行性。谢谢各位老师，请批评指正。

工程实现补充材料

导师要求：每人加讲自己的工程实现（输入/输出/代码展示/结果展示）·对照《工程实现补充材料.docx》

过渡

约 20 秒

从PPT切到工程实现文档

前面17页讲的是研究方法和实验结果，接下来按老师的要求，补充讲一下工程实现部分——输入输出、数据集、代码、结果这四块，对照的是另外一份文档。

操作 切换到《工程实现补充材料.docx》，翻到"一、整体流水线"

一 · 整体流水线

约 1 分钟

输入 → 处理 → 输出

一条流量记录进来，走五步：标准化、模型推理、算复合异常得分、k-Sigma动态判决。具体来说，30维原始特征先用训练时拟合好的StandardScaler做归一化；送进模型后，残差编码器把它升到512维，Transformer在512维空间建模全局依赖，得到潜在表征，再并行输出重构向量、15类概率、二分类概率；这几个输出合成一个异常得分s，再跟动态阈值 θ 比较，最终输出正常、已知攻击、还是疑似未知这三种判决之一。

操作 翻到"二、数据集展示"

二 · 数据集展示

约 1.5 分钟

94,497条记录长什么样

数据集经过精简后，一共94,497条记录，15个类别，30维特征。文档里列了完整的类别分布表——BENIGN 5万条最多，SQL Injection只有87条最少。下面这张表是三条真实记录的节选，可以看到不同类型流量在目标端口、流持续时间、包速率上的差异，比如GoldenEye这条，流持续时间将近993万微秒，比正常流量长得多，这正是这类攻击的特征之一。

操作 指着真实样本表格念一两个数字即可，不用逐字念完，翻到"三、代码架构"

三 · 代码展示

约 2.5 分钟

三个文件，三段核心代码

代码分三个文件：`model.py`只放模型结构定义；`train.py`是训练脚本；`demo_test.py`是我今天现场演示用的脚本。

第一段代码是模型的前向传播——一行行看：输入经过`encode`得到512维潜在表征 z ，然后`decode`重构回30维，同时并行走多分类头和二分类头，一次前向传播出四个输出。

第二段是训练时的损失组合，重构、分类、二分类三项按1.0/2.0/1.5加权求和，这跟论文里的公式完全对应。

第三段是`k-Sigma`动态阈值的核心代码——注意这个`update`方法开头这一行"`if not is_normal: return`"，这一行代码就是论文里说的攻击样本隔离机制：异常样本直接跳过，不进队列、不参与统计量更新。

操作 翻到"四、结果展示"

四 · 结果展示

约 1.5 分钟

现场跑`demo_test.py`的真实结果

这张表是我在本机现场跑`demo_test.py`，对全部9450条测试集重新推理一遍得到的结果，不是提前写好的数字。可以看到，准确率、F1、召回率、误报率跟论文报告的数值方向都一致，都是比较强的结果；误报率这一项现场跑出来是11.28%，论文报告是8.7%，有几个百分点的差异，我们排查过，判决规则是对的，用的就是跟论文一致的`k-Sigma`动态阈值判决，初步怀疑是当前加载的模型checkpoint保存时间点跟论文数据对应的那次训练不完全是同一个版本，这个我还在核实。

如果老师追问这个差异，如实说清楚"方向一致、数值有小幅波动、原因在核实"，不要说"完全一致"——这跟前面报告里"如实标注"的原则是一样的。

操作 如果时间允许，可以现场打开终端跑一遍 `demo_test.py`（README里有说明），让老师看到真实推理过程；如果时间紧，直接展示文档里的结果表格即可

附 答辩委员会常见追问准备

基于论文内容整理，不是原稿部分，供临场应对

Q1: 0.7 和 0.3 这个复合得分权重是怎么定的？

这是在验证集上做敏感性分析选出的组合：重构项系数更高，是为了保留对未知攻击的敏感性（生成式信号），分类项作为对已知攻击判别力的补充。这跟训练时三个损失的权重（1.0/2.0/1.5）是两件不同的事——一个是训练阶段的损失权重，一个是推理阶段合成异常得分的权重，不能混着问。

Q2: 为什么选 CIC-IDS2018，不用更新的数据集？

CIC-IDS2018 是目前网络入侵检测领域最权威的公开基准之一，规模大、攻击类型覆盖全面，便于跟已有工作横向对比。论文展望里也明确写了，跨数据集验证是下一步要做的工作，这是当前研究范围的边界，不是回避的问题。

Q3: 跟已发表的 SOTA 方法比较过吗？

目前论文里的实验主要是内部消融——本文方法内部不同模块组合的对比，用来定量归因各创新点的贡献。跟已发表方法的横向对比是投稿改写阶段要补充的工作。

Q4: $k=1.5$ 、 $W=1000$ 这两个超参数怎么选的？

通过超参数敏感性分析，扫描不同的 k 值和窗口大小，在准确率、误报率、长期波动率之间做权衡，这一组在 CIC-IDS2018 上综合表现最优。

Q5: "疑似未知"和真正的未知攻击是一回事吗，怎么验证的？

验证方式是留出法：训练时故意不让模型见过某4类攻击，测试时把这4类当作"未知攻击"来检验模型能不能靠重构误差和分类置信度的联合信号把它们标记出来，而不是靠真实世界里从没出现过的全新攻击类型——这是学术研究里模拟未知攻击的标准做法，因为真正意义上"从没见过"的攻击没法在带标签的数据集里获得。

Q6: 现场跑出来的误报率11.28%和论文报告的8.7%对不上，为什么？

判决规则是对的，现场用的就是跟论文一致的 k -Sigma动态阈值判决，不是简化算法。目前怀疑是当前加载的best_model.pth，跟当年生成论文classification_report.txt数据的那次训练checkpoint不完全是同一个版本——训练之后可能又跑过或保存过更新的版本。方向上现场结果和论文是一致的、都是强结果，具体数值差异的原因还在核实，如实说明即可，不需要回避。